



UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PROGRAMA DE POSGRADOS

GESTIÓN DE PROYECTOS IT

PROYECTO FINAL IMPLEMENTACIÓN DE SGSI PARA PROTECCIÓN DE ACTIVOS TECNOLÓGICOS

Autor (es):

Lima Barrios Mildred Madai mlimab1@miumg.edu.gt
Ayala Estrada Adrián Esteban aayalae@miumg.edu.gt
Ajuchan Castillo Misael Alexander majuchanc5@miumg.edu.gt
Cristales Rivera Kenia Marisol kcristalesr@miumg.edu.gt
Quezada Gallardo Angelo Diancarlo aquezadag1@miumg.edu.gt

Profesor

Ing. MA. Mario Estuardo Chajon Arriaza

Curso

Gestión de Proyectos IT– primer trimestre – 2026

NOTA 20 puntos

Guatemala, 2026

INDICE

INTRODUCCIÓN	6
VISIÓN DE LA EMPRESA	7
OBJETIVOS DE LA EMPRESA	8
General	8
Específicos	8
ANTECEDENTES	8
MARCO CONCEPTUAL	9
Sistema de Gestión de Seguridad de la Información (SGSI) y sus principios	10
• Confidencialidad:	10
• Integridad:	10
• Disponibilidad:	10
Activos de información en una empresa tecnológica	11
a) Código Fuente:	11
b) Datos de clientes:	11
c) Diseños y productos innovadores:	11
a) Infraestructura tecnológica:	11
Riesgo: amenazas, vulnerabilidades e impacto	12
Controles de seguridad alineados con la situación del proyecto	12
Controles de acceso a infraestructura y servidores	12
Protección de propiedad intelectual y secretos comerciales	13
Gestión de riesgos en el ciclo de vida del software (SDLC)	13
Auditorías de seguridad de aplicaciones y procesos	13
Medidas básicas para cerrar brechas inmediatas	13
• Firewall	14
• Antivirus corporativo:	14
• Filtrado web:	14
• Monitoreo de red:	14
Identificación de Activos	14
Criterios de clasificación usados	14
Clasificación de la información (sugerida):	14
Inventario de activos	15
Clasificación y ponderación de riesgos	15

Tabla 1	15
Probabilidad (P)	15
Impacto (I)	16
Tabla 2	16
<i>Matriz Probabilidad (P) vs Impacto (I)</i>	16
Matriz	17
Tabla 3	17
Tabla 4	18
<i>mapa de calor:</i>	18
GRUPO DE PROCESOS INICIACIÓN	18
Acta de Constitución	19
Tabla 5	19
Información del Proyecto	20
Listado de Interesados	22
Tabla 6	22
Registro de Interesados	23
Tabla 7	23
Propósito y Justificación del Proyecto	25
Grupo de Procesos Planificación	26
a) Descripción del Proyecto y Entregables	26
Enunciado del alcance.	26
Descripción de Roles	27
Tabla 8	27
Matriz de Asignación de Responsabilidades	28
Tabla 9	28
Tabla 10	29
d) EDT	30
Imagen 1	30
e) Organigrama del Proyecto	33
Imagen 2	33
f) Objetivos del Proyecto	34
g) Premisas y Restricciones	34
i) Riesgos iniciales de alto nivel	35

h) Cronograma de hitos principales (Primer Trimestre 2026)	35
Imagen 3.....	35
i) Red de Proyecto	35
Imagen 4.....	36
j) Costeo de Proyecto.....	36
k) Presupuesto estimado	36
Imagen 5.....	36
m) Plan de Configuración.....	37
n) Documentación de Requisitos de Proyecto.....	37
ñ) Plan de Gestión de Cambios	38
o) Plan de Gestión de Calidad	39
p) Plan de Gestión de Recursos	40
q) Plan de Gestión de Comunicación	41
r) Evaluación de Riesgos.....	42
s) Plan de Respuesta de Riesgos	43
t) SOW (Statement of Work)	43
Grupo de Procesos Ejecución	44
a) Lección Aprendida	44
b) Encuesta de Satisfacción sobre el Trabajo en Equipo.....	44
c) Evaluación de Competencias Generales	45
d) Acta de reunión.....	46
Tabla 11	46
Tabla 12	47
Tabla 13	48
d) Registro de incidentes.....	50
Tabla 14	50
f) Acta de aceptación de entregables.....	51
Tabla 15	51
Tabla 16	52
Grupo de procesos monitoreo.....	53
a) Informe de métrica de calidad	53
Tabla 17	53
Tabla 18	55

b) Solicitud de cambio	55
Tabla 19	56
c) Estado de solicitud de cambio	57
Tabla 20	57
GRUPO DE PROCESOS CIERRE DE PROYECTO.....	59
a) Checklist de cierre de proyecto	59
Tabla 21	59
b) Encuesta de satisfacción de interesados	60
Tabla 22	61
c) Acta de aceptación del proyecto	61
Tabla 23	61
Tabla 24	62
d) Informe de desempeño del proyecto	62
Tabla 25	63
Tabla 26	63
Tabla 27	64
Tabla 28	64
Conclusiones y Recomendaciones	65
Conclusiones:.....	65
Recomendaciones:.....	65
Bibliografía y referencias	66
Anexos	66

INTRODUCCIÓN

En el mundo actual, para una empresa de tecnología, su activo más valioso no son las oficinas ni el mobiliario, sino lo que tiene dentro de sus servidores: el código fuente, los datos de sus clientes y los diseños innovadores que les dan una ventaja competitiva, sin embargo, tener todo este oro digital por así decirlo, expuesto a internet sin las protecciones adecuadas es como dejar la bóveda de un banco abierta y esperar que nadie entre para robarlo.

Actualmente, la empresa enfrenta un reto crítico, aunque operamos conectados al mundo, no tenemos un verdadero escudo contra virus, ataques externos o accesos no autorizados. Esta falta de controles no solo pone en riesgo la propiedad intelectual, sino que también podría detener nuestra operación diaria por completo.

Este proyecto surge de la necesidad para dejar de correr riesgos y empezar a gestionar nuestra seguridad de manera seria. A través de la implementación de un Sistema de Gestión de Seguridad de la Información, buscamos establecer medidas fundamentales:

- a) Protección Perimetral y de Equipos: Instalación de firewalls y antivirus corporativos para detener amenazas antes de que lleguen a nuestros datos.
- b) Control de Acceso: Asegurarnos de que solo las personas correctas accedan a la infraestructura de desarrollo.
- c) Navegación Segura: Implementar filtrado web para evitar sitios maliciosos y monitorear la red en tiempo real.
- d) Cultura de Desarrollo Seguro: Evaluar riesgos en cada etapa de la creación de software, pasando de un modelo reactivo a uno preventivo.

El objetivo es claro, transformar nuestra infraestructura en un entorno sólido y confiable. Queremos garantizar que el talento de la empresa esté protegido y que la continuidad del negocio no dependa de la suerte, sino de una estrategia de seguridad firme y bien estructurada.

VISIÓN DE LA EMPRESA

La empresa tiene una meta clara: consolidarse como una organización tecnológica que no solo sea reconocida por la calidad de sus soluciones, sino también por tomarse en serio la seguridad de la información. Y es que, en un mundo digital donde los riesgos crecen casi al mismo ritmo que las oportunidades, no basta con reaccionar ante los problemas. La visión es otra: hacer de la seguridad un pilar estratégico del negocio, no un parche que se pone cuando algo ya salió mal.

Lo que se busca, en el fondo, es un cambio de mentalidad. Que proteger el código fuente, los datos de los clientes y los diseños de productos no sea solo tarea del equipo de TI, sino parte de la cultura de toda la organización. Algo así como cuando en una casa todos cuidan de cerrar bien la puerta, no solo quien tiene la llave. Eso implica que cada proceso (desde el análisis y desarrollo de software hasta la implementación y el mantenimiento) incorpore criterios de confidencialidad, integridad y disponibilidad como algo natural, no como un trámite más. La verdad es que la seguridad, vista así, deja de ser un freno y se convierte en algo que fortalece la confianza y, de paso, la competitividad.

Además, la implementación del Sistema de Gestión de Seguridad de la Información (SGSI) se entiende como ese primer paso firme hacia una madurez organizacional real. No se trata únicamente de tener firewall, antivirus corporativo, filtrado web o monitoreo de red (que sí, son importantes), sino de construir una estructura formal que permita identificar riesgos de manera ordenada, priorizar lo que realmente importa y empujar una mejora continua que no se quede en el papel. Con eso, la idea es reducir la exposición tanto a amenazas externas como a esas vulnerabilidades internas que a veces pasan desapercibidas, y garantizar que la operación no se detenga cuando surja un incidente inesperado.

A mediano y largo plazo, la aspiración va más allá de lo técnico. La organización quiere que sus clientes y aliados estratégicos la vean como una empresa confiable, responsable y, sobre todo, resiliente. Porque en el sector tecnológico, la confianza no se gana solo con buenos productos; se gana demostrando que la información está protegida y que hay capacidad de respuesta cuando las cosas se complican. Por eso, la visión no se limita a reforzar controles técnicos. También apuesta por fortalecer la conciencia y el compromiso

del equipo humano, entendiendo que la seguridad es una responsabilidad compartida, no un asunto de unos pocos.

Y finalmente, la empresa se posiciona como una organización dispuesta a adaptarse a los cambios del entorno digital, incorporando buenas prácticas y estándares reconocidos en gestión de seguridad. Así, la innovación tecnológica y la protección de los activos críticos avanzan de la mano no como fuerzas opuestas, sino como aliadas, abriendo camino hacia un crecimiento sostenible y una posición competitiva sólida en el mercado.

OBJETIVOS DE LA EMPRESA

General

Desarrollar el modelo para un sistema de gestión de seguridad de la información (SGSI), con la finalidad de proteger código fuente, información sensible de colaboradores y diseños de productos pertenecientes a la marca.

Específicos

- a) Identificar riesgos y vulnerabilidades que afectan a la disponibilidad, integridad y confidencialidad de la información.
- b) Diseñar planes de seguridad y mitigación contra amenazas, basados en procedimientos establecidos en un sistema de gestión de seguridad de la información (SGSI).

ANTECEDENTES

La empresa, dedicada al desarrollo de software a la medida y soluciones tecnológicas innovadoras, puede gestionar activos de información críticos para su operación y dar ventaja competitiva. Incluyen códigos fuente propietario, datos confidenciales de clientes y diseños de productos en desarrollo. La infraestructura tecnológica actual se compone de estaciones de trabajo de alto rendimiento y servidores de desarrollo, todos con conectividad permanente a Internet, esencial para las actividades de investigación, colaboración y operaciones diarias.

La organización padece de una baja postura de seguridad proactiva y consolidada. Siendo el caso que tiene ausencia de controles técnicos para mitigar amenazas. Notamos que no se implementan firewalls perimetrales o de generación nueva para el filtrado y monitoreo del tráfico de red, incluye que no se aplican políticas de filtrado de web para restringir el

acceso a sitios maliciosos o redes sociales. Vemos que no se realiza monitoreo continuo de la red para detectar actividades anómalas, basado a esta información quiere decir que no existe una solución corporativa unificada con gestión centralizada.

La situación genera una exposición que pone en riesgo la confidencialidad, integridad y disponibilidad. Al notar esto podría haber pérdida o robo de la propiedad intelectual, esto compromete la ventaja competitiva, en este punto entran las interrupciones operativas debido a la infección de software maliciosos o ataque de denegación de servicio, uno de los riesgos más grandes es el acceso no autorizado. Necesitamos salvar los activos críticos, debemos mantener la confianza y asegurar la continuidad de negocio, esto quiere decir que debemos establecer una base sólida de ciberseguridad. Esta base debe alinearse con las mejores prácticas de un Sistema de Gestión de Seguridad de la Información.

Se justifica que el primer paso debe ser la implementación de un conjunto de controles técnicos esenciales, firewall, antivirus corporativo, filtrado web y monitoreo. Esto debería establecer defensas perimetrales contra amenazas externas, debemos proteger los endpoints contra software maliciosos, pero teniendo en cuenta la reducción del ataque y vulnerabilidades al tener esto tenemos que sentar bases para futuras etapas de SGSI, como la segmentación de red y respuesta a incidentes. Al definir estos temas nos queda garantizar un uso seguro de los recursos de internet para evitar riesgos operacionales.

MARCO CONCEPTUAL

En una empresa tecnológica, la información no es un simple “recurso de apoyo”: muchas veces es el activo que sostiene el negocio. El código fuente concentra conocimiento, horas de trabajo y decisiones técnicas; los datos de clientes representan confianza, reputación y obligaciones de confidencialidad; y los diseños de productos innovadores contienen el valor diferencial que permite competir en el mercado. Cuando este tipo de organización trabaja con equipos conectados a Internet y no cuenta con protecciones suficientes, se vuelve especialmente vulnerable a incidentes como infecciones por malware, accesos indebidos, fugas de información o interrupciones operativas.

Bajo este escenario, hablar de seguridad no debería reducirse a acciones aisladas (por ejemplo, “instalar un antivirus y ya”). La seguridad necesita orden, continuidad y

responsabilidades claras. Ahí es donde cobra sentido un Sistema de Gestión de Seguridad de la Información (SGSI), porque permite que la protección de la información se trate como un proceso permanente: se planifica, se implementa, se revisa y se mejora. Este marco conceptual desarrolla los conceptos esenciales para entender por qué un SGSI es pertinente en una empresa de tecnología y cómo se conectan sus elementos con medidas prácticas como firewall, antivirus corporativo, filtrado web y monitoreo de red.

Sistema de Gestión de Seguridad de la Información (SGSI) y sus principios

Un SGSI puede entenderse como una forma estructurada de gestionar la seguridad, donde la empresa deja de actuar únicamente “cuando algo pasa” y empieza a trabajar con un enfoque preventivo y controlado. En términos prácticos, el SGSI integra políticas, procedimientos, roles, responsables y controles, alineados a las prioridades del negocio. Es decir, la seguridad deja de depender de decisiones improvisadas y se convierte en una práctica organizacional con objetivos definidos.

Dentro del SGSI hay tres principios que funcionan como guía para tomar decisiones y priorizar controles:

- **Confidencialidad:** la información debe ser accesible solo para quienes tienen autorización. No se trata únicamente de “ocultar” datos, sino de aplicar accesos por necesidad real y evitar que información sensible quede disponible para cualquiera dentro o fuera de la organización.
- **Integridad:** la información debe mantenerse completa, correcta y protegida frente a modificaciones no autorizadas. Si se realizan cambios, estos deberían poder rastrearse, de forma que exista claridad sobre qué se modificó, quién lo hizo y por qué.
- **Disponibilidad:** los usuarios que dependen de la información deben poder acceder a ella cuando la necesiten. Un sistema “muy seguro” pero inusable o que se cae continuamente también perjudica al negocio.

Estos principios son especialmente críticos en empresas tecnológicas porque una falla puede afectar tanto lo técnico como lo comercial. Por ejemplo, si se pierde la disponibilidad de servicios internos, se frena el desarrollo; si se afecta la integridad del código o de un

repositorio, se introducen errores costosos; y si se rompe la confidencialidad de datos de clientes, el daño reputacional puede ser inmediato.

Activos de información en una empresa tecnológica

Para proteger bien, primero hay que saber qué se está protegiendo. En un SGSI, los activos de información son todos los recursos que tienen valor para la organización y cuya pérdida, alteración o exposición afectaría la operación. En el caso planteado, los principales activos son:

a) Código Fuente:

El código fuente no solo representa el producto; también representa conocimiento y ventajas competitivas. Si se filtra, se pierde control sobre el esfuerzo invertido y se abre la puerta a copias, uso no autorizado o explotación de vulnerabilidades.

b) Datos de clientes:

Los datos de clientes son sensibles por naturaleza. Además de su valor comercial (relación y confianza), suelen estar vinculados a compromisos de privacidad y buenas prácticas de protección. Un incidente aquí no se limita a “perder datos”: puede afectar la imagen de la empresa y generar consecuencias legales o contractuales.

c) Diseños y productos innovadores:

Diseños, prototipos, documentación técnica y especificaciones son parte de la propiedad intelectual. En tecnología, el diferencial competitivo a menudo depende de lo que todavía no está en el mercado; por eso, proteger la innovación es clave.

a) Infraestructura tecnológica:

Servidores, repositorios, estaciones de trabajo, red interna y herramientas de desarrollo forman el entorno donde viven los activos. Si esta infraestructura se vulnera, se afecta todo: desde la continuidad del negocio hasta la integridad de los proyectos.

Proteger activos no significa tratarlos todos igual. En la práctica, es necesario entender su criticidad (qué tan grave sería perderlos), su ubicación (dónde residen), su uso (quién los necesita) y su exposición (qué tan accesibles están desde Internet o desde redes internas).

Riesgo: amenazas, vulnerabilidades e impacto

El concepto de riesgo es central en un SGSI porque permite priorizar. Un riesgo ocurre cuando una amenaza se aprovecha de una vulnerabilidad y produce un impacto. En una empresa tecnológica conectada a Internet, estas piezas suelen verse así:

- Amenazas: malware, ataques externos, intentos de intrusión, phishing, robo de credenciales, fugas de información, uso indebido de accesos o explotación de fallas en aplicaciones.
- Vulnerabilidades: ausencia de controles, configuraciones débiles, equipos sin protección o sin actualizaciones, falta de monitoreo, permisos excesivos, contraseñas inseguras o procesos de desarrollo sin revisiones de seguridad.
- Impacto: interrupción de servicios, pérdida o exposición de información, daño reputacional, costos de recuperación, retrasos en proyectos, caída de productividad y pérdida de confianza de clientes.

Este enfoque ayuda a entender por qué “poner herramientas” no es suficiente. Dos empresas pueden tener antivirus, pero si una administra permisos correctamente, monitorea eventos y audita cambios, su riesgo real será mucho menor. El SGSI busca precisamente esa gestión integral: elegir controles según riesgos reales, medirlos, revisarlos y ajustarlos.

Controles de seguridad alineados con la situación del proyecto

En el escenario descrito, donde existen brechas básicas (virus, ataques y accesos no autorizados), los controles deben empezar por lo esencial y atacar puntos críticos. Los siguientes controles son particularmente relevantes:

Controles de acceso a infraestructura y servidores

El objetivo aquí es que el acceso deje de ser “abierto” o “por costumbre” y pase a ser controlado y justificado. Una práctica clave es el mínimo privilegio: cada persona debe tener solamente los permisos necesarios para cumplir su función. Esto reduce el daño potencial si una cuenta se compromete o si ocurre un error humano.

También es importante proteger recursos sensibles: servidores, repositorios de código y bases de datos. En estos puntos se concentra la información más valiosa, y un acceso indebido puede causar daños difíciles de revertir. Por último, la trazabilidad es esencial:

registrar y observar accesos permite detectar patrones raros (por ejemplo, accesos en horarios inusuales o intentos repetitivos) y facilita la investigación cuando algo sucede.

Protección de propiedad intelectual y secretos comerciales

El conocimiento es uno de los activos más “codiciados” en tecnología. Por eso, este control busca reducir la posibilidad de fuga o copia no autorizada de diseños y código. No se trata de desconfiar del personal, sino de reconocer que los incidentes pueden ocurrir por múltiples razones: descuidos, errores, dispositivos inseguros o malas prácticas.

Un enfoque responsable incluye limitar accesos por proyecto, establecer reglas claras sobre el uso y almacenamiento de información, y asegurar que solo quienes trabajan directamente con un componente tengan acceso al material sensible. Así se reduce el riesgo sin bloquear la productividad.

Gestión de riesgos en el ciclo de vida del software (SDLC)

La seguridad no debería añadirse al final, cuando el producto ya está listo y solo queda “parchar”. Integrar seguridad en el ciclo de vida del software (SDLC) significa considerar riesgos desde el inicio: análisis, diseño, desarrollo, pruebas y despliegue. Cuando se detecta una vulnerabilidad temprano, corregirla suele ser más rápido y menos costoso.

Además, el SDLC recuerda algo importante: los sistemas cambian. Actualizaciones, nuevas funcionalidades y correcciones pueden introducir riesgos nuevos. Mantener prácticas seguras durante cambios evita que el software se convierta en un punto de entrada para ataques.

Auditorías de seguridad de aplicaciones y procesos

Las auditorías funcionan como un “chequeo” formal: confirman si los controles se están aplicando y si están dando resultados. Esto incluye revisiones periódicas, pruebas de seguridad y documentación de hallazgos. Lo valioso de este control es que convierte la seguridad en un ciclo de mejora continua: se identifica el problema, se corrige y se verifica que realmente se haya resuelto.

Medidas básicas para cerrar brechas inmediatas

Dado que la empresa presenta exposición por equipos conectados a Internet y protección insuficiente, el proyecto plantea medidas base que atacan amenazas frecuentes:

- **Firewall:** ayuda a filtrar tráfico y a bloquear accesos no autorizados. Bien configurado, reduce la superficie de ataque y separa mejor los entornos críticos.
- **Antivirus corporativo:** protege estaciones de trabajo y servidores contra malware, con administración centralizada y actualizaciones controladas.
- **Filtrado web:** reduce el riesgo asociado a navegación insegura, bloqueando sitios maliciosos o categorías de alto riesgo.
- **Monitoreo de red:** permite detectar actividades fuera de lo normal y responder con rapidez. El monitoreo no solo reacciona; también genera evidencia para analizar incidentes y mejorar controles.

Estas medidas suelen ser el “primer paso” porque elevan rápidamente el nivel de seguridad, reducen incidentes comunes y crean una base para implementar controles más maduros dentro del SGSI.

Con la aplicación de controles y medidas dentro de un enfoque SGSI, la empresa debería lograr una reducción tangible de riesgos: menos infecciones por malware, menos accesos indebidos, mejor protección de información crítica y mayor continuidad operativa. Además, el uso de Internet se vuelve más controlado y se disminuyen vulnerabilidades asociadas a la navegación o al uso de equipos sin protección.

Más allá del resultado inmediato, el valor del SGSI es que deja instalada una lógica de trabajo: responsables claros, controles revisables y mejora continua. En otras palabras, no se trata solo de “resolver el problema de hoy”, sino de crear condiciones para que la seguridad se mantenga en el tiempo y crezca conforme la empresa evoluciona.

Identificación de Activos

Criterios de clasificación usados

Clasificación de la información (sugerida):

- **Pública:** divulgación no genera impacto relevante.
- **Interna:** uso interno; divulgación genera impacto moderado.
- **Confidencial:** divulgación afecta reputación/operación.

- **Restringida / Crítica:** divulgación o alteración compromete seriamente el negocio (PI, datos sensibles, continuidad).

Criterios CIA (Confidencialidad, Integridad, Disponibilidad)
Se asigna prioridad Alta / Media / Baja según el daño esperado si se pierde C/I/D.

Inventario de activos

Clasificación y ponderación de riesgos

Escalas de evaluación (1 a 5)

Tabla 1

Inventario de activos y clasificación

Nota. Se visualiza la tabla con el listado de activos identificados para la implementación del sistema de seguridad y su clasificación correspondiente. Fuente propia.

ID	Activo	Tipo	Dueño (rol)	Ubicación	Clasificación	C	I	D	Justificación breve
A1	Código fuente (repositorios)	Información	Líder de Desarrollo / DevOps	Repositorio (Git), servidores	Restringida/Crítica	Alta	Alta	Media	Es PI central; filtración o cambios afectan ventaja y seguridad
A2	Datos de clientes	Información	Responsable de Producto / TI	BD/CRM/archivos	Restringida/Crítica	Alta	Alta	Alta	Datos sensibles; exposición implica reputación y obligaciones
A3	Diseños / prototipos / specs	Información	I+D / Producto	Repositorios, drives internos	Restringida/Crítica	Alta	Alta	Media	PI e innovación no publicada; fuga daña competitividad
A4	Servidores de desarrollo (VMs/hosts)	Infraestructura	TI/Infra	Data center / nube	Confidencial	Media	Alta	Alta	Si se compromete, cae operación y se altera código/datos
A5	Estaciones de trabajo (devs)	Infraestructura	TI/Soporte	Endpoints	Interna/Confidencial	Media	Media	Media	Son puerta de entrada a credenciales y dispositivos
A6	Red interna (switches, wifi, VPN)	Infraestructura	TI/Redes	Oficina / túneles	Confidencial	Media	Media	Alta	Sin monitoreo y segmentación, facilita intrusiones
A7	Credenciales (AD, Git, VPN, llaves)	Información	TI/Seguridad	Gestor/AD	Restringida/Crítica	Alta	Alta	Alta	Robo habilita acceso no autorizado (riesgo principal)
A8	Backups (código/BD/configs)	Información	TI/Infra	NAS/Cloud	Confidencial/Restringida	Alta	Alta	Alta	Sin backups confiables, recuperación ante incidente es lenta
A9	Herramientas SDLC (CI/CD, trackers)	Servicio	DevOps	GitLab/Jenkins/Azure DevOps	Interna/Confidencial	Media	Alta	Media	Alteración afecta despliegues y calidad/seguridad
A10	Logs/monitoreo de red y seguridad	Servicio	TI/Seguridad	SIEM/NMS	Confidencial	Media	Alta	Alta	Sin trazabilidad no se detecta ni investiga

Probabilidad (P)

1. Rara (casi no ocurre)

2. Baja (podría pasar una vez al año)
3. Media (podría pasar varias veces al año)
4. Alta (probable en cualquier momento)
5. Muy alta (ya está ocurriendo o es recurrente)

Impacto (I)

1. Menor (molestias sin detener operación)
2. Bajo (afecta un área; recuperación rápida)
3. Moderado (interrumpe parcialmente; costo notable)
4. Alto (afecta operación; reputación/entregas)
5. Crítico (paro significativo; fuga grave; pérdidas mayores)

Puntaje de Riesgo = $P \times I$ (1–25)

Clasificación:

- 1–5: Bajo
- 6–10: Medio
- 11–15: Alto
- 16–25: Crítico

 Bajo (1–5) |  Medio (6–10) |  Alto (11–15) |  Crítico (16–25)

Tabla 2

Matriz Probabilidad (P) vs Impacto (I)

P \ I	1	2	3	4	5
5	 B	 M	 A	 C	 C
4	 B	 M	 A	 C	 C

P \ I	1	2	3	4	5
3	 B	 M	 M	 A	 A
2	 B	 B	 M	 M	 M
1	 B	 B	 B	 B	 B

Nota. Se visualiza la matriz de probabilidad e impactos para la implementación del sistema de seguridad para la empresa. Fuente propia.

Matriz

Set base de riesgos como amenazas/vulnerabilidades típicas (malware, intrusión, phishing, fuga, permisos excesivos, falta de monitoreo, etc.)

Tabla 3

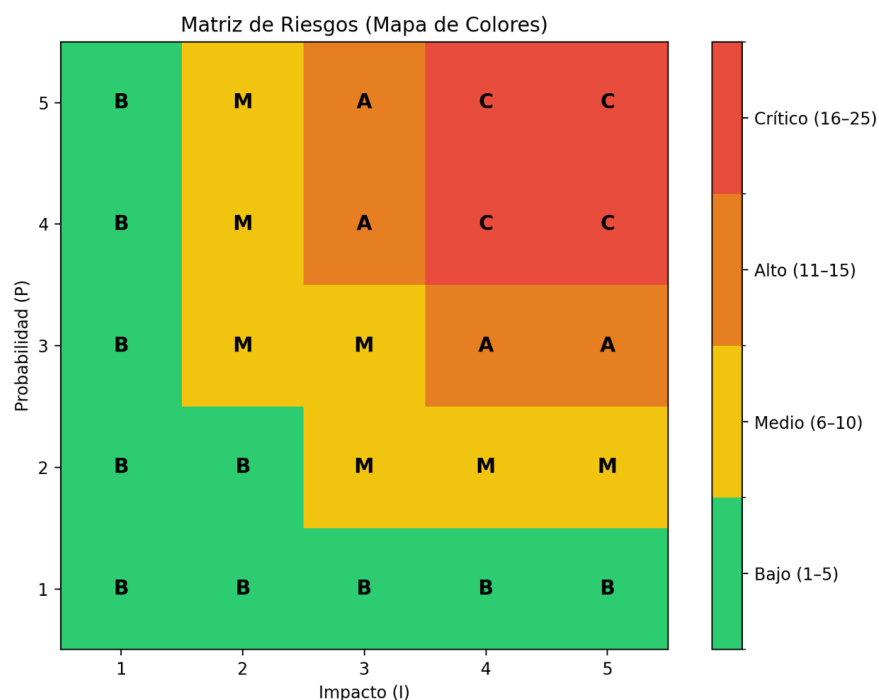
Matriz con riesgos asociados

ID Riesgo	Activo(s) afectado(s)	Amenaza	Vulnerabilidad principal	Impacto (CIA)	P	I	Score	Nivel
R1	A5, A7, A1	Malware/Ransomware	Endpoints sin protección/gestión central (brecha base)	D alta / I alta	4	5	20	Crítico
R2	A7, A1, A2	Phishing / robo de credenciales	Contraseñas débiles / falta de MFA / poca cultura	C alta / I alta	4	4	16	Crítico
R3	A1, A3	Fuga de propiedad intelectual (código/diseños)	Permisos excesivos / acceso “por costumbre”	C alta	3	5	15	Alto
R4	A4, A6	Intrusión externa / explotación	Falta de firewall/segmentación/filtrado	C/I/D altas	4	5	20	Crítico
R5	A2	Exposición de datos de clientes	Falta de control de acceso y auditoría	C crítica	3	5	15	Alto
R6	A4, A6	Caída de servicios / DoS	Sin monitoreo y respuesta temprana	D alta	3	4	12	Alto
R7	A1, A9	Alteración del código / pipeline (supply chain)	Falta de control y revisión segura SDLC	I alta	3	4	12	Alto
R8	A8	Pérdida de backups / recuperación fallida	Backups no probados / sin política	D alta	2	5	10	Medio
R9	A10	Incidentes no detectados a tiempo	Falta de logs/monitoring continuo	C/I/D altas	4	4	16	Crítico

Nota. Se visualiza la tabla con el listado de riesgos identificados para la implementación del sistema de seguridad y su clasificación correspondiente. Fuente propia.

Tabla 4

mapa de calor:



Nota. Se visualiza la tabla con el mapa de calor asociado a la implementación del sistema de seguridad y su clasificación correspondiente. Fuente propia.

GRUPO DE PROCESOS INICIACIÓN

En este contexto, el Grupo de Procesos de Iniciación marca el arranque formal del proyecto. Es como ese momento en que la empresa deja de decir “algún día hay que arreglar esto” y, por fin, lo convierte en algo real: una iniciativa con forma, con permiso, con dirección. Y la verdad es que aquí la necesidad ya estaba gritando la exposición de activos digitales críticos, pero faltaba transformarla en un proyecto estructurado, autorizado y conectado con la estrategia de la organización.

Esta fase no se limita a definir qué se va a hacer, sino también por qué se va a hacer y bajo qué condiciones va a caminar todo esto. Porque no es lo mismo decir “hay riesgos” que reconocer que el código fuente, los datos de clientes o los diseños de productos están, literalmente, demasiado cerca del peligro. Y es que una cosa es sentir la preocupación, y otra es sentarse y decir: “va, hagámoslo bien, desde el inicio”.

Acta de Constitución

Tabla 5

Acta de constitución de sistema de Gestión de Seguridad de la información (SGSI) y controles básicos de Seguridad Informática.

ACTA DE CONSTITUCIÓN DEL PROYECTO (PROJECT CHARTER)			
A. Información general			
Nombre del proyecto:	Implementación de un sistema de Gestión de Seguridad de la información (SGSI) y controles básicos de Seguridad Informática.	Fecha de preparación:	01 de febrero de 2026
Elaborado por:	Grupo 3 – Gestión de proyectos	Autorizado por:	Ing. Mario Chajon
B. Necesidad del proyecto			
Actualmente se almacena código fuente, diseños de productos innovadores, datos de clientes y proveedores en carpetas alojadas en servicios de la nube, sin contar con protección adecuada contra ataques informáticos, accesos no autorizados o virus. Dicha situación representa un nivel alto de riesgo para la integridad, confidencialidad y disponibilidad de la información de la empresa, resultando en la interrupción de la continuidad operativa, desprestigio empresarial y pérdida de datos.			
C. Objetivos del proyecto			
- Objetivo general Desarrollar el modelo para un sistema de gestión de seguridad de la información (SGSI), con la finalidad de proteger código fuente, información sensible de colaboradores y diseños de productos pertenecientes a la marca. - Objetivos específicos a) Identificar riesgos y vulnerabilidades que afectan a la disponibilidad, integridad y confidencialidad de la información. b) Diseñar planes de seguridad y mitigación contra amenazas, basados en procedimientos establecidos en un sistema de gestión de seguridad de la información (SGSI).			
D. Alcance del proyecto			

El proyecto debe ser capaz de analizar riesgos de seguridad informática con la implementación de firewalls y configuraciones de reglas de acceso e instalaciones de antivirus corporativo	
E. Descripción del producto	
El producto será una infraestructura tecnológica protegida mediante controles básicos de seguridad tomando como prioridad el correcto funcionamiento de los siguientes puntos.	
a) Sistema de filtrado web activo 24/7 b) Firewall configurado c) Antivirus funcionando en todos los equipos pertenecientes a la empresa. d) Monitoreo de red e) Políticas documentadas de control de acceso f) Informe de análisis y mitigación de riesgos. g) Capacitaciones y concientización a colaboradores.	
F. Participantes del proyecto	
Coordinador del proyecto:	Adrián Ayala
Miembros del equipo:	Adrián Ayala Misael Ajuchan Mildred Lima Angelo Quezada Kenia Cristales
Otros involucrados:	Ing. Mario Chajon
G. Fecha del proyecto	
Tiempo estimado: 6 meses Inicio proyecto: 15 de enero de 2026 Finalización de proyecto: 30 de junio de 2026	

Nota: Se visualiza el acta de constitución perteneciente al sistema de Gestión de Seguridad de la información (SGSI) y controles básicos de Seguridad Informática. Fuente propia.

Información del Proyecto

Se realizará la implementación de un sistema de gestión de seguridad de información en conjunto con ciertos controles técnicos indispensables de ciberseguridad. Entre las principales acciones se contempla la instalación y configuración de un firewall, antivirus corporativo en cada uno de los equipos pertenecientes a la empresa, la configuración de filtro de paginas web mediante DNS seguro y un sistema de monitoreo de red.

La red de la empresa será segmentada por medio de VLANs y se implementará la autenticación doble factor en los repositorios que almacenan el código y consolas de administración del firewall, permitiendo la evaluación y mitigación de riesgos en el ciclo de vida del desarrollo, planeación y entrega de software. Así mismo, se dará prioridad a la capacitación y concientización de usuarios y la importancia de la documentación formal de políticas y procedimientos de seguridad.

El proyecto será llevado a cabo bajo la necesidad de proteger los activos de la empresa, como el código fuente, datos confidenciales de proveedores, clientes y empleados, diseños de productos innovadores y resguardo de la imagen e integridad de la empresa, protegiendo la ventaja competitiva y estabilidad operativa.

Con la implementación busca reducir significativamente riesgos relacionados a carencia de instrucciones, comunicación, seguridad y protocolos. Manteniendo pautas claras, se obtendrán reducciones en incidentes como intrusiones, infecciones por programa maligno, ataques de phishing, accesos no autorizados y filtrado de información. Con este plan, se pretende garantizar los principios fundamentales de la seguridad de la información.

El giro de negocio principal es la empresa tecnológica como organización, protegiendo su ventaja competitiva y garantizando la estabilidad operativa. Beneficiando directamente a los equipos conformantes de la empresa, como desarrollo, calidad, infraestructura, administrativa y direcciones, reduciendo riesgos asociados al uso cotidiano de los sistemas.

Obteniendo impactos positivos en clientes y proveedores, al obtener un nivel mayor de confianza debido a los procesos de resguardo de la información, gestionada bajo controles formales de seguridad.

El tiempo de ejecución, es de 16 semanas, iniciando el 15 de enero de 2026 y finalizando el 30 de junio de 2026. El cronograma ha sido creado para darle importancia y atención a cada paso y proceso realizado a lo largo de la implementación. En el ámbito financiero, el presupuesto planificado es de \$ 45,000.00 considerando una variación del 2% (\$ 45,900.00) considerada y aprobada para el proyecto.

Listado de Interesados

Documento inicial dentro de la gestión de proyectos que identifica a todas las personas, grupos y participantes que pueden influir en el proyecto o verse impactados por el resultado de este. El listado constituye el primer paso y posteriormente es ampliado en el registro de interesados. A continuación, el listado de interesados.

Tabla 6

Listado de interesados de interesados

Departamento/Tipo interesado	Posible beneficio
Project Manager	Esta área se ve beneficiada al fortalecer la experiencia en gestión de proyectos tecnológicos y de seguridad.
Departamento de soporte	Area responsable de la implementación técnica de controles. El área se beneficia al contar con herramientas y obtener visibilidad de red y reducción de peligros críticos.
Departamento de desarrollo de software	El área administrativa se verá beneficiada con la implementación de antivirus, filtrado de la información web y monitoreo, reduciendo el riesgo de infecciones y ataques, mejorando la estabilidad del sistema.
Departamento administrativo y operativo	La implementación de antivirus, filtrado web y monitoreo reduce directamente el peligro de inestabilidad en el sistema y posibles ataques mediante canales de comunicación de la empresa.
Clientes	Se ven beneficiados debido a la seguridad en el almacenamiento y manejo de sus datos, reduciendo la probabilidad de incidentes que afecten servicios o datos.
Usuarios internos	Los empleados que utilizan sistemas informáticos se ven beneficiados al trabajar en un entorno mas seguro.

Nota: Se lista el listado de interesados para el sistema de Gestión de Seguridad de la información (SGSI) y controles básicos de Seguridad Informática. Fuente propia.

Registro de Interesados

El registro de interesados es un documento formal que amplía el listado inicial que se planteó inicialmente en el listado de interesados, contiene información detallada sobre cada uno de ellos, rol dentro del proyecto, nivel de influencia, interés, expectativas, comunicación, entre otras. A continuación, el registro de interesados.

Tabla 7

Registro de interesados del proyecto.

Nombre/Grupo	Rol	Nivel de influencia	Nivel de interés	Expectativas	Canal de comunicación
Dirección general	Solicitante del proyecto	Alta	Alta	Reducción de riesgos, protección de la reputación de la empresa y control presupuestario.	Informes ejecutivos semanales, seguimiento y aprobación del hito clave del proyecto.
Adrián Ayala	Project manager	Alta	Alta	Se espera el cumplimiento de los alcances en tiempo, costo y calidad mediante la coordinación efectiva.	Reuniones semanales de avances, en las cuales se da seguimiento al cronograma y comunicación constante.
Misael Ajuchan/Equipo TI	Líder técnico y soporte IT	Alta	Alta	Implementación de la solución exitosa, resolución de problemas surgentes y estabilidad operativa.	Reuniones con el equipo técnico y canales directos de comunicación.

Equipo de desarrollo	Usuarios interesados por nivel de beneficio	Media	Alta	Protección de código sin afectar el rendimiento de productividad del equipo.	Sesiones informativas constantes y capacitaciones técnicas con retroalimentación continua.
Area de administración y operativa	Usuarios internos	Media	Media	Se espera poder usar el internet sin que se afecten las tareas diarias.	Capacitaciones, correos informativos y soporte por parte del área de IT.
Clientes	Beneficiarios externos	Alta	Alta	Protección de datos, continuidad de servicio y confianza en la empresa	Comunicaciones formales sobre mejoras de seguridad, reporte de cumplimiento cuando sea requerido.
Kenia Cristales	Consultor de seguridad informática	Media	Alta	Correcta aplicación de controles y consolidación del sistema.	Participación en auditorías, reuniones estratégicas y reportes de evaluación de riesgos.
Proveedores	Proveedor/tercero de soluciones	Media	Media	Implementación adecuada de productos y cumplimiento contractual.	Coordinación técnica, seguimiento de licencias y comunicación durante implementación y soportes.

Nota: Se visualiza el registro de interesados para el sistema de Gestión de Seguridad de la información (SGSI) y controles básicos de Seguridad Informática. Fuente propia.

Propósito y Justificación del Proyecto

Implementar bases sólidas con ayuda de expertos en ciberseguridad, con la implementación de un sistema de gestión de seguridad de la información y controles técnicos esenciales, permitiendo de esta manera a la empresa, proteger activos críticos como código fuente, información sensible y diseño de productos.

Incorporación de herramientas profesionales para el control de riesgos como lo son firewalls, antivirus, filtrado de páginas web y autenticación doble factor. Obteniendo de esta manera un modelo proactivo.

Se busca cubrir con controles técnicos implementados adecuadamente y falta de gestión formal de seguridad. Se ha generado exposición a amenazas registradas en antecedentes de la empresa. Haciendo uso de la oportunidad de fortalecer la cultura de seguridad dentro de la empresa, se busca alinear al personal a las buenas prácticas de gestión y mantenimiento de la información.

Se adoptarán herramientas, políticas, responsabilidades y procesos que permiten obtener una visión estratégica completa del entorno de seguridad de la empresa, parte importante del negocio. Se obtiene la oportunidad de aumentar la confianza del público objetivo mediante la demostración de responsabilidad y confianza frente a riesgos digitales.

Se realiza el proyecto buscando concientizar la importancia de la seguridad de la información en las empresas, teniendo como premisa ser el activo mas valioso de la corporación. El costo de implementar acciones y controles preventivos es menor en comparación con el impacto que puede repercutir en un incidente. La inversión reduce la posibilidad de pérdidas y garantiza la continuidad de operaciones dentro de la organización, mejorando la confianza del mercado y fortaleciendo la ventaja competitiva mantenida por la empresa.

Grupo de Procesos Planificación

a) Descripción del Proyecto y Entregables

Se implementará un conjunto de medidas de seguridad informática buscando la creación de un sistema de gestión de seguridad de la información, con el objetivo principal de fortalecer la protección de activos críticos de la empresa tecnológica. Se prioriza la organización, operación e infraestructura conectada permanentemente a internet, de una manera controlada y registrada, con planes reactivos y protocolos preventivos para la protección de código fuente, información de clientes y diseños de productos innovadores.

Se ha contemplado la aplicación de controles una definición de políticas y procesos técnicos primordiales, para la gestión de riesgos estructurados. Se consideran los siguientes entregables del proyecto:

- i. Diagnóstico inicial del entorno de seguridad y análisis de la empresa.
- ii. Implementación y configuración de software (Firewalls y segmentación de red)
- iii. Implementación de antivirus en servidores y cada dispositivo conectado a la empresa directamente.
- iv. Configuración, implementación y capacitación a usuarios del filtro web DNS seguro.
- v. Implementación de sistema de monitoreo de red.
- vi. Inversión e implementación de la autenticación doble factor, para las maquinas y repositorios de código y documentos sensibles.
- vii. Creación y documentación de políticas de seguridad.
- viii. Documentación de tratamientos de incidentes de seguridad.
- ix. Capacitación de usuarios internos y finales.
- x. Informe final de entrega del proyecto.

Enunciado del alcance.

Se sigue el ciclo de vida de un proyecto, planificación, implementación y ejecución de controles técnicos y administrativos dirigidos a la protección de infraestructura y activos de información pertenecientes a la organización. Se busca realizar la evaluación de riesgos, adquisición e instalación de herramientas de seguridad, segmentación de red y configuración de acceso bajo el principio del mínimo privilegio, con énfasis en la documentación de políticas, capacitación y concientización del personal.

El proyecto será evaluado con pruebas en ambiente piloto, monitoreadas por un tiempo prudencial y validaciones de funcionamiento constantes, registrando los incidentes y documentando las actas de cierre formales, con la aceptación por el solicitante. Se incluyen cambios aprobados para representar ayuda al fortalecimiento en el nivel de seguridad y evitar comprometer los activos de la empresa.

Actualmente no se tiene contemplado en el primer alcance la certificación formal en estándares internacionales, renovación completa de infraestructura tecnológica o rediseño total de la arquitectura de red y activos de la empresa. El proyecto actual está enfocado en el establecimiento e introducción de ciberseguridad sobre la infraestructura existente.

Descripción de Roles

Para la correcta implementación del proyecto se requiere definir roles y responsabilidades en el equipo y la parte interesada, a continuación, se listan.

Abreviación, Rol, descripción del rol

Tabla 8

Roles para la implementación del sistema de seguridad.

Rol	Descripción del rol
Director general	Es responsable de aprobar presupuesto, validación de decisiones y aceptación formal de entregables del proyecto. Debe proporcionar apoyo ejecutivo y asegurar el seguimiento correcto de los objetivos iniciales.
Project mánager	Es responsable de planificar, coordinar, monitorear y cerrar el proyecto. Debe supervisar el cumplimiento del cronograma, presupuesto y alcance de gestión de riesgos y mantener una comunicación fluida entre los participantes e interesados del proyecto.
Líder técnico y equipo de TI	Son responsables de implementar la solución planteada en el proyecto, siguiendo cada una de

	las fases detallando cada proceso en documentación, y participar en pruebas piloto y dar soporte en la transición del proyecto.
Consultor de seguridad informática	Debe asesorar la evaluación, definición de riesgos y políticas, alineando el proyecto a las buenas prácticas y validando que la implementación sea correcta.
Equipo de desarrollo	Son responsables de proteger los repositorios con el código mediante validaciones de funcionamiento y controles de seguridad, asegurando que la solución implementada no afecte la productividad.
Usuarios finales	Son responsables de recibir capacitaciones y cumplir con políticas establecidas.

Nota. Se listan los roles y responsabilidades para la implementación del sistema de Gestión de Seguridad de la información (SGSI) y controles básicos de Seguridad Informática. Fuente propia.

Matriz de Asignación de Responsabilidades

Tabla 9

Significado de RACI

Abreviación	Ingles	Descripción
R	Responsible	Responsable para ejecutar la actividad.
A	Accountable	Responsable de aprobar la actividad / Responsable final
C	Consulted	La actividad debe ser consultada
I	Informed	Debe ser informado.

Nota. Se listan cada una de las abreviaciones pertenecientes a “RACI”, significado en inglés y descripción. Fuente propia.

Tabla 10*Matriz de asignación de responsabilidades*

Entregable	Director general	Project manager	LT y Equipo TI	Consultor de seguridad	Equipo desarrollo	Usuarios Finales
Elaboración de acta de constitución	A	R	C	C	I	I
Diagnóstico inicial y análisis de riesgos	I	A	R	R	C	I
Definición de políticas de seguridad	I	A	C	R	C	I
Adquisición de herramientas	A	R	C	C	I	I
Implementación de firewalls y segmentación de red	I	A	R	C	I	I
Implementación antivirus	I	A	R	C	I	I
Configuración para filtrado web	I	A	R	C	I	I
Implementación de monitoreo de red	I	A	R	C	I	I
Implementación de autenticación multifactor	I	A	R	C	C	I

Pruebas piloto y validaciones técnicas	I	A	R	C	R	I
Capacitación a usuarios finales	I	A	R	C	I	R
Gestión de incidentes en el periodo de implementación	I	A	R	C	C	I
Aprobación de entregables	A	R	C	C	I	I
Cierre formal del proyecto	A	R	C	C	I	I

Nota. Se listan las responsabilidades y quien las realiza, para la implementación del sistema de Gestión de Seguridad de la información (SGSI) y controles básicos de Seguridad Informática. Fuente propia.

d) EDT.

Imagen 1

Diagrama de estructura de desglose de negocio

ESTRUCTURA DE DESGLOCE DE NEGOCIO

INICIO DEL PROYECTO	1.1 Elaboración del Acta de Constitución 1.2 Identificación y registro de interesados 1.3 Reunión de lanzamiento del proyecto 1.4 Aprobación formal del proyecto		
PLANIFICACIÓN	2.1 Levantamiento de información de infraestructura actual 2.2 Diagnóstico inicial de seguridad 2.3 Identificación y análisis de riesgos 2.4 Definición del alcance detallado 2.5 Elaboración del cronograma 2.6 Definición de políticas de seguridad (uso aceptable, control de acceso) 2.7 Plan de comunicación 2.8 Plan de gestión de riesgos		
ADQUISICIÓN DE RECURSOS	3.1 Elaboración de orden de compra 3.2 Adquisición de firewall Fortinet 3.3 Adquisición de antivirus corporativo SentinelOne 3.4 Adquisición/licenciamiento de herramienta de monitoreo 3.5 Adquisición de licencias multifactor. 3.6 Verificación y registro de licencias		
IMPLEMENTACIÓN TÉCNICA	4.1 Implementación de Firewall 4.1.1 Instalación física del equipo 4.1.2 Configuración de reglas básicas 4.1.3 Segmentación de red (VLANs) 4.1.4 Pruebas de conectividad 4.1.5 Configuración de logs y alertas	4.1 Implementación de Firewall 4.1.1 Instalación física del equipo 4.1.2 Configuración de reglas básicas 4.1.3 Segmentación de red (VLANs) 4.1.4 Pruebas de conectividad 4.1.5 Configuración de logs y alertas	4.3 Configuración de Filtrado Web 4.3.1 Configuración de DNS seguro 4.3.2 Definición de categorías bloqueadas 4.3.3 Pruebas de acceso

PRUEBAS Y VALIDACIÓN	5.1 Pruebas piloto en equipo de desarrollo 5.2 Escaneo de vulnerabilidades 5.3 Simulación básica de incidentes 5.4 Corrección de hallazgos 5.5 Aprobación técnica de soluciones
CAPACITACIÓN Y GESTIÓN DE CAMBIO	6.1 Desarrollo de material de capacitación 6.2 Capacitación a usuarios internos 6.3 Difusión de políticas de seguridad 6.4 Encuesta de satisfacción
MONITOREO Y CONTROL	7.1 Seguimiento de métricas de calidad 7.2 Registro y gestión de incidentes 7.3 Evaluación de desempeño del proyecto 7.4 Gestión de solicitudes de cambio
CIERRE DEL PROYECTO	8.1 Elaboración del informe final 8.2 Documentación técnica final 8.3 Acta de aceptación de entregables 8.4 Acta de cierre formal 8.5 Documentación de lecciones aprendidas 8.6 Liberación de recursos

Nota: Se visualiza el diagrama de estructura de desglose de negocio en la implementación del sistema de Gestión de Seguridad de la información (SGSI) y controles básicos de Seguridad Informática.
Fuente propia.

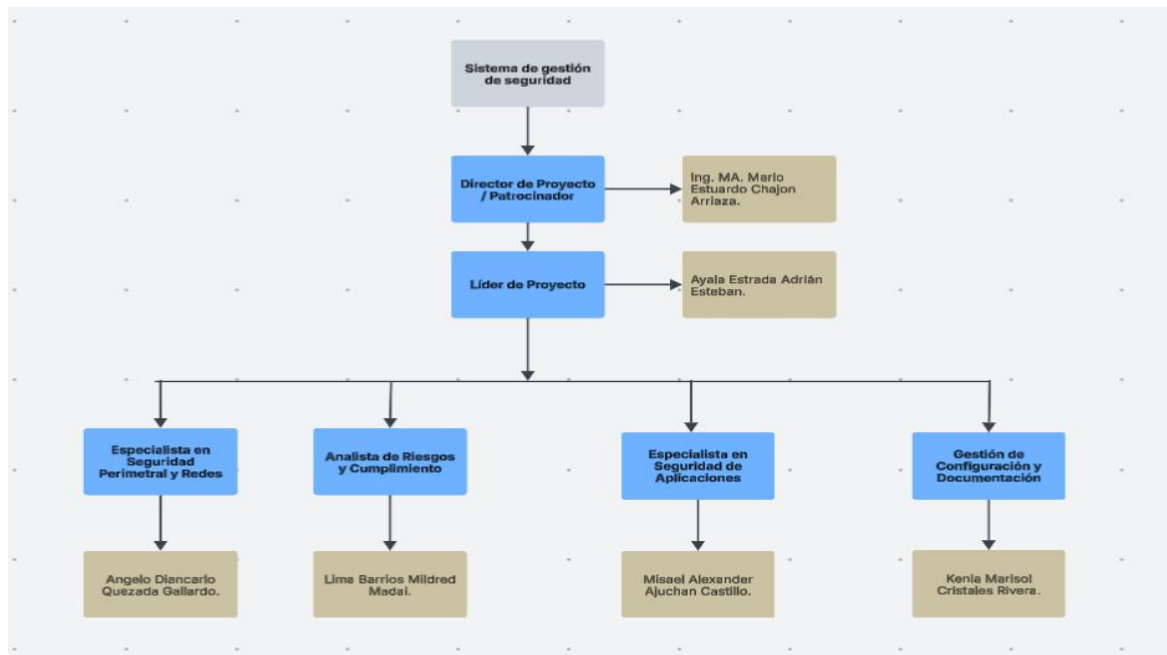
e) Organigrama del Proyecto

El equipo de trabajo se distribuye según los roles de gestión y técnicos necesarios para la implementación del sistema:

- **Director de Proyecto / Patrocinador:** Ing. MA. Mario Estuardo Chajon Arriaza.
- **Líder de Proyecto:** Ayala Estrada Adrián Esteban.
- **Especialista en Seguridad Perimetral y Redes:** Angelo Diancarlo Quezada Gallardo.
- **Analista de Riesgos y Cumplimiento:** Lima Barrios Mildred Madai.
- **Especialista en Seguridad de Aplicaciones:** Misael Alexander Ajuchan Castillo.
- **Gestión de Configuración y Documentación:** Kenia Marisol Cristales Rivera.

Imagen 2

Organigrama del proyecto



Nota. Se visualiza el organigrama perteneciente al proyecto de la implementación del sistema de seguridad. Fuente Propia.

f) Objetivos del Proyecto

- **General:** Desarrollar el modelo para un sistema de gestión de seguridad de la información (SGSI), con la finalidad de proteger código fuente, información sensible de colaboradores y diseños de productos.
- **Específicos:**
 - Identificar riesgos y vulnerabilidades que afectan a la disponibilidad, integridad y confidencialidad.
 - Diseñar planes de seguridad y mitigación basados en procedimientos de un SGSI.
 - Implementar medidas técnicas base: firewall, antivirus corporativo, filtrado web y monitoreo de red.

g) Premisas y Restricciones

- **Premisas:**
 - La infraestructura actual (estaciones de trabajo y servidores) permite la instalación de agentes de seguridad centralizados.
 - Existe conectividad permanente a Internet para actualizaciones de firmas de antivirus y firewalls.
 - La alta dirección está comprometida con el cambio de cultura organizacional hacia la seguridad.
- **Restricciones:**
 - El proyecto debe completarse durante el primer trimestre de 2026.
 - No se deben interrumpir las operaciones críticas de desarrollo de software durante la implementación.

i) Riesgos iniciales de alto nivel

- **Fuga de propiedad intelectual:** Pérdida o robo de código fuente propietario y diseños innovadores.
- **Interrupciones operativas:** Caída de servicios por infecciones de malware o ataques de denegación de servicio (DoS).
- **Accesos no autorizados:** Intrusiones externas o internas por falta de control perimetral.
- **Resistencia al cambio:** Vulnerabilidades internas generadas por el uso de equipos sin protección o navegación insegura del personal.

h) Cronograma de hitos principales (Primer Trimestre 2026)

Imagen 3

Cronograma del proyecto



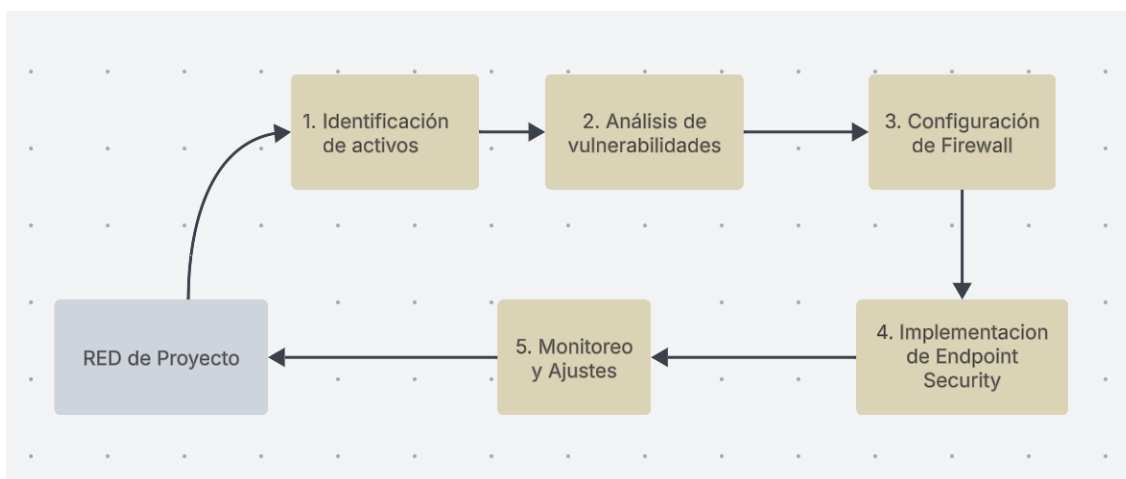
Nota. Se visualiza el cronograma perteneciente a las semanas de la implementación del proyecto. Fuente propia.

i) Red de Proyecto

La secuencia lógica de actividades o ruta crítica prácticamente se define así:

Imagen 4

Diagrama de red



Nota. Se visualiza el diagrama de red perteneciente a la implementación del sistema de seguridad. Fuente Propia.

j) Costeo de Proyecto

El costo se divide en tres categorías principales basadas en las necesidades detectadas:

1. **Hardware:** Appliance de Firewall de nueva generación (NGFW).
2. **Software (Licenciamiento):** Suscripciones anuales para Antivirus Corporativo (EDR) y Filtrado de contenido web.
3. **Recursos Humanos:** Horas de consultoría y ejecución técnica del equipo de ingeniería.

k) Presupuesto estimado

Imagen 5

Presupuesto estimado

CATEGORÍA	CONCEPTO	CANTIDAD	COSTO UNI.	TOTAL ESTIMADO
Infraestructura	Firewall Perimetral (Hardware + 1 año licencia)	1	\$1,200	\$1,200
Software	Licencias Antivirus EDR (Anual)	15	\$45	\$675
Servicios	Consultoría, Configuración y Hardening	1	\$1,500	\$1,500
Capacitación	Taller de Cultura de Seguridad para el equipo	1	\$300	\$300
Contingencia	Fondo para imprevistos técnicos (10%)	1	\$365	\$365
TOTAL				\$4,040

Nota. Se listan los gastos asociados al presupuesto perteneciente a la implementación del sistema de seguridad. Fuente Propia.

m) Plan de Configuración

Este plan garantiza que todos los elementos del proyecto estén controlados:

- **Control de Versiones:** Uso de repositorios seguros para el código fuente y documentación del SGSI.
- **Trazabilidad:** Registro de todos los cambios realizados en la configuración de servidores y firewall.
- **Línea Base:** Definición de configuraciones estándar para todas las estaciones de trabajo o computadoras.
- **Respaldo de Configuraciones:** Copias de seguridad automáticas de las configuraciones de red y bases de datos de clientes.

n) Documentación de Requisitos de Proyecto

- **Funcionales:**
 - El sistema debe bloquear el acceso a sitios de alto riesgo.

- El firewall debe segmentar el tráfico de desarrollo del tráfico administrativo.
- Debe existir una consola centralizada para gestionar amenazas en todos los equipos.
- **No Funcionales:**
 - **Disponibilidad:** Las medidas de seguridad no deben degradar el rendimiento de la red más de un 5%.
 - **Confidencialidad:** Solo el personal de TI autorizado podrá modificar las reglas de seguridad.

ñ) Plan de Gestión de Cambios

1. Introducción

La implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) en una empresa tecnológica implica un entorno dinámico, donde pueden surgir nuevas necesidades, ajustes técnicos o mejoras derivadas del monitoreo continuo. Por esta razón, se establece un Plan de Gestión de Cambios que permita administrar de forma estructurada cualquier modificación que impacte el alcance, el tiempo, el costo o la calidad del proyecto.

Este plan busca evitar desviaciones no controladas y garantizar que toda modificación esté debidamente justificada, evaluada y aprobada antes de su ejecución.

2. Objetivo

Definir el procedimiento formal para solicitar, analizar, aprobar, rechazar y documentar cambios durante el ciclo de vida del proyecto.

3. Alcance

Aplica a:

- Cambios en entregables.
- Modificaciones en cronograma.
- Ajustes presupuestarios.

- Cambios técnicos (ej. incorporación de nuevos controles).
- Cambios derivados de incidentes o auditorías.

4. Procedimiento

1. Registro formal de la Solicitud de Cambio.
2. Análisis de impacto en la triple restricción.
3. Evaluación de riesgos asociados.
4. Revisión por el Comité de Control de Cambios.
5. Decisión formal (Aprobado, Rechazado o Pendiente).
6. Actualización de líneas base.
7. Comunicación oficial a interesados.

5. Criterios de Aprobación

Un cambio será aprobado si:

- Mejora el nivel de seguridad.
- Reduce riesgos críticos.
- Es financieramente viable.
- No compromete la estabilidad operativa.

6. Control de Versiones

Todo documento afectado será actualizado y almacenado en el repositorio oficial del proyecto, manteniendo trazabilidad histórica.

o) Plan de Gestión de Calidad

1. Introducción

La calidad en un proyecto de seguridad informática no se queda solo en “cumplir técnicamente” o en instalar herramientas y decir que ya está. No, va un poco más allá. Y la verdad es que implica asegurarse de que los controles que se implementan de verdad

funcionen en el día a día, que no sean solo una configuración bonita o un check en una lista. Porque, ¿de qué sirve tener un firewall si está mal ajustado y deja pasar lo peligroso? ¿o un antivirus corporativo si nadie lo actualiza y termina siendo casi decoración?

2. Objetivo

Asegurar que los entregables cumplan con estándares técnicos y requisitos definidos.

3. Estándares Aplicables

- Buenas prácticas de seguridad informática.
- Principios de confidencialidad, integridad y disponibilidad.
- Recomendaciones basadas en ISO/IEC 27001.
- Política de mínimo privilegio.

4. Métricas de Calidad

- Cobertura de antivirus (meta 100%).
- Tiempo de respuesta a incidentes (< 4 horas).
- Disponibilidad de red (> 99.5%).
- Satisfacción de usuarios (> 4/5).

5. Control de Calidad

- Pruebas piloto.
- Escaneos de vulnerabilidades.
- Validaciones técnicas.
- Actas de aceptación de entregables.

p) Plan de Gestión de Recursos

1. Introducción

El éxito del proyecto depende de la correcta asignación de recursos humanos, tecnológicos y financieros.

2. Recursos Humanos

- Director General (Patrocinador)
- Project Manager
- Líder Técnico
- Consultor de Seguridad
- Equipo de Desarrollo
- Usuarios Finales

3. Recursos Tecnológicos

- Firewall NGFW.
- Antivirus corporativo.
- Sistema de monitoreo.
- Herramientas de autenticación multifactor.
- Equipos de red y servidores.

4. Gestión de Recursos

- Asignación clara de responsabilidades mediante matriz RACI.
- Seguimiento semanal de desempeño.
- Liberación formal al cierre del proyecto.

q) Plan de Gestión de Comunicación

1. Objetivo

Garantizar comunicación clara, oportuna y efectiva entre todos los interesados.

2. Canales de Comunicación

- Reuniones semanales de seguimiento.
- Informes ejecutivos.

- Correos formales.
- Actas de reunión.
- Reportes técnicos.

3. Frecuencia

- Comité de proyecto: semanal.
- Dirección general: informes ejecutivos quincenales.
- Equipo técnico: reuniones técnicas según avance.

4. Gestión de Conflictos

Cualquier conflicto será gestionado inicialmente por el Project Manager y escalado al patrocinador si es necesario.

r) Evaluación de Riesgos

1. Metodología

Se utiliza una matriz de probabilidad e impacto (1 a 5).

Riesgo = Probabilidad x Impacto.

2. Riesgos Identificados

- Fuga de código fuente.
- Ataques de malware.
- Accesos no autorizados.
- Resistencia al cambio.
- Sobrecostos por licencias.
- Interrupciones operativas.

3. Clasificación

- 1–5: Bajo

- 6–10: Medio
- 11–15: Alto
- 16–25: Crítico

s) Plan de Respuesta de Riesgos

1. Estrategias

- Mitigar.
- Transferir.
- Aceptar.
- Evitar.

2. Respuestas Aplicadas

- Implementación de firewall para mitigar intrusiones.
- Antivirus corporativo para mitigar malware.
- 2FA para reducir accesos no autorizados.
- Capacitaciones para reducir resistencia al cambio.
- Pruebas piloto para evitar incompatibilidades.

t) SOW (Statement of Work)

1. Descripción del Trabajo

Implementar controles técnicos y administrativos para proteger activos críticos de la empresa tecnológica.

2. Entregables Principales

- Diagnóstico inicial.
- Firewall configurado.
- Antivirus implementado.
- Filtrado web activo.

- Monitoreo de red.
- Autenticación multifactor.
- Políticas documentadas.
- Capacitaciones.
- Informe final.

3. Duración

Enero – junio 2026.

4. Presupuesto

Q45,000 con variación aprobada del 2%.

Grupo de Procesos Ejecución

a) Lección Aprendida

Durante la implementación del proyecto se evidenció que involucrar al equipo técnico desde la fase inicial redujo significativamente la resistencia al cambio y permitió identificar incompatibilidades antes del despliegue masivo. Asimismo, las pruebas piloto resultaron fundamentales para validar configuraciones sin afectar la operación general.

Se recomienda que futuros proyectos incluyan siempre una fase piloto formal y un fondo de contingencia para cambios emergentes.

b) Encuesta de Satisfacción sobre el Trabajo en Equipo

Se aplicó una encuesta interna para evaluar la percepción del trabajo colaborativo.

Resultados:

- Comunicación efectiva: 4.4 / 5
- Coordinación entre áreas: 4.5 / 5
- Claridad de roles: 4.3 / 5
- Liderazgo del PM: 4.6 / 5

- Ambiente de trabajo: 4.5 / 5

c) Evaluación de Competencias Generales

Se evaluaron competencias técnicas y blandas del equipo.

- **Competencias técnicas:**
 - **Seguridad perimetral:** El equipo supo proteger el “borde” de la infraestructura, que al final es como la puerta principal de la casa. Si esa puerta está débil, todo lo demás queda expuesto.
 - **Gestión de riesgos:** No se quedaron solo en identificar amenazas, sino que pudieron priorizarlas y tratarlas con criterio, entendiendo qué era urgente y qué podía esperar.
 - **Implementación de controles técnicos:** Se notó experiencia al configurar y poner a funcionar controles concretos, no solo recomendarlos en papel.
 - **Monitoreo y análisis de incidentes:** Además, tuvieron la capacidad de observar lo que pasaba en la red, leer señales, y reaccionar con lógica cuando aparecían alertas o comportamientos raros.
- **Competencias blandas:**
 - **Liderazgo:** Hubo dirección y empuje, pero también capacidad de escuchar, que es lo que suele evitar choques innecesarios.
 - **Trabajo en equipo:** Se logró coordinación real entre roles, sin que cada quien trabajara “en su isla”.
 - **Comunicación:** La información fluyó, no perfecta, pero sí lo suficiente para tomar decisiones a tiempo y evitar malentendidos que cuestan caro.
 - **Adaptabilidad:** Y esto fue clave, porque siempre hay cambios: un requisito nuevo, una limitación técnica, o un ajuste de última hora. El equipo supo acomodarse sin romper el ritmo.
- **Resultado general:**

El equipo contó con las capacidades necesarias para ejecutar el proyecto de forma exitosa. Y la verdad es que se notó una combinación valiosa: dominio técnico, sí, pero también una madurez organizacional que ayuda a sostener el trabajo cuando hay presión, plazos o decisiones difíciles.

- **Áreas de mejora:**

- **Profundizar en auditorías externas:** Hace falta más práctica con escenarios reales de auditoría fuera de la organización, porque ahí los criterios suelen ser más estrictos y menos flexibles.
- **Mejorar estimaciones iniciales de tiempo ante posibles cambios:** Las estimaciones pueden volverse frágiles si no se considera desde el inicio que habrá ajustes. Incluir márgenes y escenarios alternos ayudaría a no correr al final.
- **Fortalecer conocimientos en pruebas de penetración avanzadas:** Se recomienda subir el nivel en pentesting avanzado, porque no basta con detectar lo básico; los ataques complejos suelen esconderse justo donde no se mira a primera vista.

d) Acta de reunión

Acta de reunión No. 1

Proyecto: Implementación de Medidas de Seguridad Informática

Fecha: 17 de enero de 2026

Hora: 11:00 a.m. – 2:00 p.m.

Lugar: Sala de Juntas

Convocada por: Mario Estuardo Chajon Arriaza (Fundador)

Facilitador: Adrián Ayala (Project Manager)

Asistentes

Tabla 11

Tabla de asistentes

Nombre	Cargo	Área
Mario Chajon	Fundador / director general	Dirección

Adrián Ayala	Project Manager	PMO
Misael Ajuchan	Líder de Desarrollo	Tecnología
Mildred Lima	Desarrolladora Senior	I+D
Kenia Cristales	Consultora Externa	Seguridad Informática
Angelo		
Quezada	Representante de Clientes	Atención al Cliente

Nota. Se visualizan los asistentes responsables del proyecto y el área. Fuente propia

Agenda

1. Verificación de quórum y bienvenida
2. Presentación del diagnóstico inicial de seguridad
3. Análisis de incidentes recientes (intento de intrusión al Proyecto)
4. Propuesta de soluciones técnicas (firewall, antivirus, filtrado web)
5. Definición de cronograma y responsables
6. Acuerdos y compromisos
7. Cierre

Desarrollo de la reunion

Tabla 12

Puntos desarrollados en la reunion

Punto	Descripción	Conclusiones
2. Diagnóstico	Ricardo Paz expone resultados del análisis inicial: red sin segmentación, 40% de equipos sin antivirus actualizado, ausencia de firewall perimetral.	Se confirma la necesidad urgente de implementar medidas básicas de protección.
3. Incidentes	Marcos Vega reporta el intento de exfiltración de código del Proyecto (martes 11/01, 3:00 a.m.). Se detectó a tiempo, pero se evidenció la vulnerabilidad.	Se refuerza la urgencia del proyecto. Se aprueba priorizar la protección del repositorio de código.

	Ricardo presenta el paquete de soluciones: Firewall Fortinet, Antivirus corporativo SentinelOne, filtrado web	El equipo técnico valida la compatibilidad con la infraestructura actual.
4. Propuesta	mediante DNS seguro y herramienta de monitoreo Nagios.	
	Carlos Ruiz propuesta un cronograma de 8 semanas: Semana 1-2: Adquisición; Semana 3-4: Configuración; Semana 5-6: Pruebas piloto; Semana 7-8: Implementación total y capacitación.	Se ajusta para iniciar pruebas piloto en el equipo de desarrollo desde la semana 4.
5. Cronograma		

Nota. Se visualiza la tabla de los puntos tratados en las reuniones, asociados a la implementación del sistema de seguridad. Fuente Propia.

Tabla 13

Acuerdos

#	Acuerdo	Responsable	Fecha
			Límite
1	Elaborar orden de compra para los equipos y licencias	Mario Chajon	18/01/2026
2	Realizar backup completo del código fuente y datos críticos previo a implementación	Misael Ajuchan	22/01/2026
3	Seleccionar 5 equipos para pruebas piloto (equipo de I+D)	Mildred Lima	25/01/2026
4	Preparar documento de políticas de uso aceptable de Internet	Kenia Cristales	28/01/2026
5	Convocar reunión de seguimiento para revisar avances	Adrián Ayala	29/01/2026

Nota. Se visualiza el diagrama de acuerdos perteneciente a la implementación del sistema de seguridad. Fuente Propia.

Próxima reunión 21 de marzo de 2026 – 11 am

Elaborada por: Adrián Ayala – Project Manager

d) Registro de incidentes

Tabla 14

Registro de incidentes de seguridad

ID	Fecha	Hora	Descripción	Tipo	Afectación	Estado	Responsable
INC-001	11/01/2026	03:00 a.m.	Intento de descarga masiva del repositorio "Proyecto" desde IP extranjera	Intrusión / Exfiltración	Alta - Código fuente propietario en riesgo	Cerrado Contenido	- Misael Ajuchan
INC-002	18/01/2026	02:30 p.m.	Detección de ransomware en estación de recepción	Malware	Media - Afectó 1 equipo, no se propagó	Cerrado Contenido	- Soporte IT
INC-003	25/01/2026	11:15 a.m.	Acceso no autorizado a carpeta compartida "Diseños Confidenciales" desde cuenta de usuario de pruebas	Acceso indebido	Media - Se revisaron logs, no hubo modificación	En investigación	Kenia Cristales
INC-004	2/02/2026	09:45 a.m.	Correo de phishing dirigido a 15 empleados con adjunto malicioso "Factura_Urgente.exe"	Phishing	Baja - Ningún empleado ejecutó el archivo	Cerrado Capacitación realizada	- Adrián Ayala
INC-005	10/02/2026	04:20 p.m.	Caída del servidor de desarrollo por saturación de tráfico (posible DoS interno)	Disponibilidad	Alta - 2 horas sin acceso al entorno de desarrollo	Cerrado - Resuelto con reglas de firewall	Misael Ajuchan

Nota. Se visualiza el registro de incidentes de seguridad asociados a la implementación del sistema de seguridad. Fuente propia.

f) Acta de aceptación de entregables

Acta de aceptación de entregables No. 1

Proyecto: Implementación de Medidas de Seguridad Informática

Fecha: 11 de febrero de 2026

Entregable: Configuración e Implementación del Firewall Perimetral

Descripción del Entregable:

Se ha completado la instalación, configuración y puesta en marcha del Firewall Fortinet 60F en el perímetro de la red corporativa. Este dispositivo permite:

- Filtrado de tráfico entrante y saliente.
- Segmentación de red (VLANs) para separar áreas administrativas, desarrollo y servidores críticos.
- Registro de logs de conexiones y alertas en tiempo real.
- Bloqueo de tráfico malicioso basado en firmas actualizadas.

Tabla 15

Criterios de aceptación

Criterio	Cumple (SÍ/NO)	Observaciones
El firewall está físicamente instalado y conectado correctamente	SÍ	Instalado en rack del centro de datos
Se han configurado reglas básicas de acceso (permitir sólo tráfico necesario)	SÍ	Se aplicó política de mínimo privilegio
La segmentación por VLANs está operativa (Admin, Desarrollo, Servidores)	SÍ	Pruebas de conectividad exitosas
Se generan logs de actividad accesibles para monitoreo	SÍ	Integrado con herramienta Nagios
El equipo de IT puede acceder a la interfaz de administración	SÍ	Acceso restringido por IP y 2FA
Se realizaron pruebas de penetración básicas sin encontrar vulnerabilidades críticas	SÍ	Escaneo con Nessus - resultados satisfactorios

Nota. Se visualizan los criterios de aceptación asociados a la implementación del sistema de seguridad del proyecto. Fuente Propia.

Observaciones: Se recomienda actualizar las firmas del firewall semanalmente. Pendiente la configuración de alertas por correo electrónico para eventos críticos.

Tabla 16

Aceptación

Nombre	Cargo	Fecha
		30/02/202
Mario Chajon	Directora General	6
		30/02/202
Adrián Ayala	Project Manager	6
		30/02/202
Misael Ajuchan	Líder de Desarrollo	6

Nota. Se visualizan los criterios de aceptación asociados a la implementación del sistema de seguridad del proyecto. Fuente Propia.

Grupo de procesos monitoreo

a) Informe de métrica de calidad

Proyecto: Implementación de medidas de seguridad

Período: marzo 2026

Elaborado por: Adrián Ayala

Tabla 17

Métricas evaluadas

Métrica	Definición	Meta	Resultado	Análisis
Cobertura de Antivirus	% de equipos con antivirus instalado y actualizado	100%	98%	2 equipos en mantenimiento no fueron actualizados. Se programa revisión.
Tiempo de Respuesta a Incidentes	Tiempo promedio desde detección hasta contención	< 4 horas	3.2 horas	Equipo responde adecuadamente.
Disponibilidad de Red	% de tiempo sin caídas por ataques o fallos	99.50%	99.80%	Firewall funcionando correctamente.
Sitios Web Bloqueados	Número de accesos a sitios maliciosos bloqueados	N/A	147 bloqueos	El filtrado web está siendo efectivo.
Parcheo de Vulnerabilidades	% de vulnerabilidades críticas corregidas en < 7 días	90%	85%	Pendiente actualización en 3 servidores legacy.

Satisfacción de Usuarios	Encuesta a empleados sobre rendimiento del sistema	> 4.0/5.0	4.2/5.0	Usuarios perciben mejora en seguridad sin afectar rendimiento.
--------------------------	--	-----------	---------	--

Nota. Se visualizan las métricas evaluadas en la implementación del sistema de seguridad del proyecto. Fuente Propia.

Conclusión

La mayoría de las métricas se encuentran dentro de lo esperado. Quiere decir que se debe reforzar la actualización de equipos en mantenimiento y servidores, el filtrado web está siendo altamente efectivo.

Tabla 18

Acciones correctivas

Acción	Responsable	Fecha
Actualizar antivirus en equipos de mantenimiento	Soporte IT	5/04/2026
Programar ventana de parcheo para servidores	Misael	10/04/2026
	Ajuchan	

Nota. Se visualizan las acciones correctivas aplicadas en el proceso de la implementación del proyecto de seguridad. Fuente propia.

b) Solicitud de cambio

Solicitud de cambio No. 1

Proyecto: Implementación de medidas de Seguridad Informática

Fecha: 15 de abril de 2026

Solicitante: Misael Ajuchan (Líder de desarrollo)

Prioridad: Media

Descripción del cambio solicitado

Se solicita ampliar el alcance del proyecto para incluir la implementación de autenticación de dos factores (2FA/MFA) en el acceso a los repositorios de código fuente (GitLab) y a la consola de administración del firewall

Justificación

Durante el monitoreo de enero, se detectaron 3 intentos de acceso no autorizado a cuentas de desarrolladores (INC-003). Aunque fueron contenidos, se evidencia que solo la contraseña no es suficiente. La implementación de 2FA reduciría significativamente el riesgo de compromiso de cuentas privilegiadas.

Tabla 19*Impacto del cambio*

Área	Impacto	Descripción
Alcance	+ Aumenta	Se agrega un nuevo componente de seguridad
Tiempo	+ 2 semanas	Requiere configuración, pruebas y capacitación
Costo	+ Q3,500	Licencias de MFA (Duo Security / Google Workspace)
Calidad	+ Mejora	Aumenta el nivel de seguridad sin afectar rendimiento
Riesgo	Reduce	Disminuye probabilidad de acceso no autorizado

Nota. Se visualizan el impacto de las principales áreas en la implementación del proyecto de seguridad. Fuente propia.

Aprobación

Decisión: Aprobado

Comentario: Se aprueba el cambio considerando los incidentes recientes y criticidad.

Firma: Mario Chajon

Fecha: 17/01/2026

c) Estado de solicitud de cambio

Estado de solicitud de cambio

Proyecto: Implementación de Medidas de Seguridad Informática

Fecha de consulta: 30 de enero de 2026

Tabla 20

Impacto del cambio

ID Solicitud	Descripción	Fecha		Estado	
		Solicitud	Solicitante	Actual	Comentarios
SC-001	Implementar 2FA/MFA en repositorios y firewall	15/03/2026	Misael Ajuchan	En Ejecución Pendiente	Licencias adquiridas. Configuración en progreso.
SC-002	Extender filtrado web a dispositivos móviles corporativos	22/03/2026	Angelo Quezada	Aprobación	En evaluación de costo/beneficio.
SC-003	Actualizar política de contraseñas (longitud 12 caracteres)	25/03/2026	Kenia Cristales	Rechazada	Se considera suficiente política actual + 2FA.
SC-004	Adquirir licencia adicional de antivirus para servidores legacy	28/03/2026	Misael Ajuchan	Aprobada	Compra autorizada. Implementación junio.
SC-005	Realizar auditoría externa de penetración	30/03/2026	Mario Chajon	Pendiente	Se presupuestará para Q3 2025.

Nota. Se visualizan el impacto de las principales áreas de impacto del cambio del proyecto de seguridad. Fuente propia.

GRUPO DE PROCESOS CIERRE DE PROYECTO

a) Checklist de cierre de proyecto

Checklist de cierre de proyecto

Proyecto: Implementación de Medidas de Seguridad Informática

Fecha de cierre: 30 de junio de 2026

Project Manager: Adrián Ayala

Tabla 21

Checklist de cierre del proyecto

Ítem	Descripción	Cumple	Observaciones
1. Entregables			
1.1	¿Todos los entregables han sido completados y aceptados?	SÍ	Ver actas de aceptación
1.2	¿Se entregó la documentación técnica (manuales, configuraciones)?	SÍ	Repositorio compartido con IT
2. Proveedores			
2.1	¿Todos los contratos con proveedores están cerrados?	SÍ	Fortinet, SentinelOne, Nagios
2.2	¿Las licencias adquiridas están activas y registradas?	SÍ	Vigencia 1 año
3. Recursos Humanos			
3.1	¿Se liberaron formalmente los recursos del equipo?	SÍ	Acta de liberación firmada
3.2	¿Se realizó la capacitación final a usuarios?	SÍ	Asistencia: 45 empleados
4. Lecciones Aprendidas			
4.1	¿Se documentaron las lecciones aprendidas?	SÍ	Ver documento anexo

4.2	¿Se realizó reunión de cierre con el equipo?	SÍ	28/06/2025
5. Financiero			
5.1	¿El presupuesto ejecutado está dentro de lo planificado?	SÍ	Desviación: +2% (aprobado)
5.2	¿Todos los costos están cerrados y facturados?	SÍ	
6. Archivo			
6.1	¿Se archivó toda la documentación del proyecto?	SÍ	Carpeta compartida "Proyecto_Seguridad_Cierre"
6.2	¿Se entregó copia de seguridad de la documentación a Dirección?	SÍ	"

Nota. Se visualizan el checklist del proyecto de seguridad. Fuente propia.

b) Encuesta de satisfacción de interesados

Encuesta de satisfacción – Proyecto de Seguridad

Proyecto: Implementación de Medidas de Seguridad Informática

Fecha: 25 de abril de 2026

Responsable: Adrián Ayala

Preguntas:

1. El proyecto cumplió con los objetivos planteados
2. La comunicación durante el proyecto fue adecuada
3. Las soluciones implementadas (firewall, antivirus) no afectan negativamente mi trabajo diario
4. Me siento más seguro/a trabajando después del proyecto
5. La capacitación recibida fue clara y útil
6. Recomendaría este enfoque para futuros proyectos
7. Satisfacción general con el proyecto

Tabla 22*Comentarios deseados*

Grupo	Comentario
Desarrollo	Al principio me preocupaba que el firewall ralentizara el acceso a repositorios externos, pero no ha sido así. Buen trabajo.
Administración	Me gustó la capacitación, ahora entiendo por qué no puedo entrar a ciertas páginas.
IT	El monitoreo nos ha salvado de varios incidentes. Herramientas muy acertadas.
Cliente	Agradecemos que nos informaran sobre las mejoras de seguridad. Nos da tranquilidad como clientes.

Nota. Se visualizan el listado de los comentarios deseados pertenecientes al proyecto de seguridad. Fuente propia.

c) Acta de aceptación del proyecto**Acta de aceptación del proyecto**

Proyecto: Implementación de Medidas de Seguridad Informática

Código: PROY-SEG-2026-001

Fecha: 30 de junio de 2026

Declaración de Aceptación:

Por medio de la presente, representando por los abajo firmantes, declara formalmente la ACEPTACIÓN Y CIERRE del Proyecto "Implementación de Medidas de Seguridad Informática".

Se confirma que todos los entregables han sido completados, probados y transferidos a operación, cumpliendo con los criterios de calidad y alcance definidos en el acta de constitución del proyecto y sus respectivas modificaciones aprobadas.

Tabla 23*Entregables Finales Aceptados*

#	Entregable	Fecha Aceptación	Acta Asociada
1	Diagnóstico inicial de seguridad	15/03/2026	INF-001

2	Implementación de Firewall Perimetral	30/04/2026	ACT-001
3	Implementación de Antivirus Corporativo	15/05/2026	ACT-002
4	Configuración de Filtrado Web	30/05/2026	ACT-003
5	Sistema de Monitoreo de Red (Nagios)	10/06/2026	ACT-004
6	Implementación de 2FA/MFA (cambio aprobado)	25/06/2026	ACT-005
7	Capacitación a usuarios y manuales	25/06/2026	ACT-006
8	Documentación final y lecciones aprendidas	28/06/2026	ACT-007

Nota. Se visualizan el listado de los entregables finales aceptados en la implementación del proyecto de seguridad. Fuente propia.

Tabla 24

Cierre formal

Rol	Nombre
Sponsor / director general	Carlos Chajón
Project Manager	Adrián Ayala
Líder Técnico	Misael Ajuchan
Usuario Clave / Desarrollo	Mildred Lima
Representante de IT	Kenia Cristales

Nota. Se visualizan el cierre final del proyecto de seguridad. Fuente propia.

d) Informe de desempeño del proyecto

Informe de desempeño del proyecto

Proyecto: Implementación de Medidas de Seguridad Informática

Período: Enero – junio 2026

Elaborado por: Adrián Ayala – Project Manager

Versión: 1.0 – Final

Resumen ejecutivo

El proyecto Implementación de Medidas de Seguridad Informática ha sido completado exitosamente dentro del plazo estimado (16 semanas) y con una desviación

presupuestaria mínima del +2% (aprobada). Se implementaron controles críticos: firewall perimetral, antivirus corporativo, filtrado web, monitoreo de red y autenticación de dos factores (2FA).

Logro principal: Se ha reducido significativamente la exposición a riesgos cibernéticos, protegiendo los datos de clientes y la operación diaria de la empresa.

Tabla 25

Desempeño por Línea Base

Línea Base	Planificado	Ejecutado	Variación
		100% + 1	
Alcance	100% entregables	cambio (2FA)	+1 entregable
		12 semanas	+4 semanas (por
Tiempo	8 semanas (15/01 - 10/05)	(15/01 - 30/06)	cambio 2FA)
Costo	Q45,000	Q45,900	+Q900 (+2%)
Calidad	Satisfacción > 4.0	Satisfacción 4.5	Superada

Nota. Se visualizan el listado del desempeño por línea base del proyecto de seguridad. Fuente propia.

Tabla 26

Indicadores Clave de Desempeño (KPIs)

KPI	Valor	Interpretación
Cumplimiento de entregables	100%	Todos los entregables aceptados formalmente
Incidentes post-implementación	3 (todos menores)	El sistema está respondiendo adecuadamente
Tiempo medio de respuesta a incidentes	3.2 horas	Por debajo del umbral de 4 horas
Satisfacción de interesados	4.5 / 5.0	Alta satisfacción general
Desviación presupuestaria	2%	Dentro del margen de tolerancia (5%)

Tabla 27*Gestión de riesgos*

Riesgo Identificado	Impacto	Probabilidad	Mitigación Aplicada	Estado Final
Resistencia al cambio por usuarios	Medio	Baja	Capacitaciones y comunicación temprana	Mitigado
Incompatibilidad de software con antivirus	Alto	Media	Pruebas piloto en entorno de desarrollo	Mitigado
Fuga de información durante implementación	Alto	Baja	Backup completo y monitoreo intensivo	Mitigado
Sobrecosto por licencias no previstas	Medio	Media	Se gestionó cambio (2FA) con aprobación	Aceptado

Nota. Se visualizan la gestión de riesgos asociados a la implementación del proyecto de seguridad. Fuente propia.

Tabla 28*Lecciones aprendidas*

Lección	Recomendación para futuros proyectos
Involucrar al equipo de desarrollo desde el inicio evitó conflictos técnicos	Mantener mesas de trabajo multidisciplinarias desde la fase de planificación
Las pruebas piloto fueron clave para detectar incompatibilidades	Siempre incluir fase de piloto antes del despliegue masivo
La comunicación constante con los usuarios redujo la resistencia	Establecer un canal de comunicación (ej. newsletter semanal)
El cambio de 2FA fue necesario, pero retrasó el cierre	Prever un fondo de contingencia para mejoras emergentes

Nota. Se visualizan las lecciones aprendidas asociados a la implementación del proyecto de seguridad. Fuente propia.

Conclusiones y Recomendaciones

Conclusiones:

- El proyecto ha sido exitoso en todos sus objetivos principales.
- La organización ahora cuenta con una base sólida de ciberseguridad.
- Se ha creado una cultura de seguridad incipiente en los empleados.

Recomendaciones:

1. Mantener actualizadas las licencias y firmas de los sistemas implementados.
2. Realizar una auditoría externa de penetración en Q3 2026 para validar la robustez de las defensas.
3. Establecer un proceso de mejora continua basado en las métricas de calidad.
4. Extender gradualmente las medidas de seguridad a los dispositivos móviles y al teletrabajo.

Bibliografía y referencias

- International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection—Information security management systems—Requirements. ISO.
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. U.S. Department of Commerce.
- Project Management Institute. (2021). A guide to the Project Management Body of Knowledge (PMBOK® Guide) (7th ed.). Project Management Institute.
- Project Management Institute. (2021). The standard for project management. Project Management Institute.

Anexos

Anexo A. Inventario de activos de información.

Anexo B. Matriz de probabilidad e impacto.

Anexo C. Mapa de calor de riesgos.

Anexo D. Acta de constitución del proyecto.

Anexo E. Formatos de seguimiento, control de cambios y cierre.